

Reportistica SOC Avanzata: Analisi Phishing - Eredità Sospetta

TRACCIA DELL'INCIDENTE - Dati Grezzi dell'Alert

```
datasource: email
timestamp: 05/12/2026 07:33:51.336
subject: Inheritance Alert: Unknown Billionaire Relative Left You Their Hat Fortunes
sender: eileen@trendymillineryco.me
recipient: support@tryhatme.com
attachment: None
content: A long lost billionaire relative has left you their secret hat empire To claim your inheritance
send us your banking details immediately
direction: inbound
```

1. L'Approccio Iniziale: Davanti a un nuovo Alert

Quando l'**alert** è apparso sul nostro schermo, non ci siamo fatti prendere dal panico e non abbiamo iniziato a **cliccare a caso**. Abbiamo applicato la **Forma Mentis del SOC Analyst: leggere, estrarre, pianificare**.

Le domande che ci siamo posti all'inizio:

- **Qual è il vettore di attacco?** Email in entrata (**direction: inbound**).
- **Qual è l'esca?** Una finta eredità milionaria per creare un falso senso di urgenza e spingere l'utente a cedere i propri **dati bancari** tramite **ingegneria sociale**.
- **Quali sono i dati iniziali su cui indagare?** Mittente **eileen@trendymillineryco.me**, destinatario **support@tryhatme.com** e **assenza di allegati (attachment: None)**.

Lezione imparata: in un contesto aziendale, capire l'impatto interno, cioè se il collega ha effettivamente risposto consegnando i dati, ha **priorità assoluta** rispetto al semplice **blocco del mittente**.

2. La Metodologia in Splunk: Padronanza dello Strumento

Prima di scrivere qualsiasi **comando** in **SPL** (Splunk Processing Language), abbiamo analizzato l'ambiente di lavoro, capendo il perché di ogni pannello.

- **Time Picker:** prima di **cercare**, isoliamo il momento dell'attacco. Abbiamo impostato il filtro partendo dalle **07:33:51** del giorno dell'incidente, per non **appesantire il sistema** e non **inquinare i risultati**.
- **Fields Sidebar:** Splunk fa il **parsing** dei log grezzi. Campi come **direction**, **sender** e **recipient** mostrano subito quali **dati** sono stati **registrati**.
- **Event Actions:** espandendo un log grezzo, un **muro di testo** diventa una **tabella ordinata chiave-valore**, utile per estrarre **informazioni** rapidamente.

3. L'Indagine Passo-Passo (La Cyber Kill Chain)

Abbiamo diviso l'indagine in due fasi, seguendo i **passi logici dell'attaccante**.

Fase A: Verificare la "Delivery" (La Consegna)

- **Il comando:** **index=email recipient="support@tryhatme.com"**
- **Il ragionamento:** volevamo isolare l'email di phishing nei log di posta per confermare l'ingresso.
- **Il risultato:** l'email è stata effettivamente recapitata al bersaglio e non era solo un **tentativo bloccato a monte**.

Fase B: Verificare la "Execution" (L'Azione dell'Utente e della Rete)

- **Il comando:** **index=email sender="support@tryhatme.com" recipient="*@trendymillineryco.me"**
- **Il ragionamento:** abbiamo **invertito i ruoli logici** per cercare una **potenziale risposta della vittima** verso l'attaccante. Il **wildcard** ***@trendymillineryco.me** permette di intercettare eventuali **alias diversi** dello stesso **dominio**.
- **Il risultato:** **0 eventi**. La **vittima non ha mai risposto al dominio sospetto**.

4. La Conclusione: Le 4 Domande di Chiusura

Un'indagine può dirsi conclusa solo quando le domande di **scoping** hanno una **risposta chiara**.

- **Vettore di ingresso: phishing email, scam finanziario. Risposto.**
- **Paziente zero / bersaglio:** utente **support@tryhatme.com**. **Risposto.**
- **Esecuzione / interazione:** l'utente ha interagito? **No**, non ci sono **log in uscita** verso il **dominio sospetto**. **Risposto.**
- **Impatto finale:** i dati sono compromessi? **No**. La catena d'attacco si è spezzata grazie all'inazione dell'utente. **Risposto.**

5. Estrazione degli IOC e Reportistica (Incident Response)

L'ultimo miglio è la documentazione. Un'indagine non documentata è un'indagine inutile. Gli **IOC** estratti sono:

- **Mittente:** eileen@trendymillineryco.me
- **Dominio malevolo:** trendymillineryco.me

L>alert è stato classificato come **True Positive**: l>alert ha individuato correttamente una **minaccia reale**. Il report strutturato deve includere:

- **Timeline degli eventi:** ricezione dell'email alle **07:33:51**, **verifica della consegna** e **controllo delle possibili risposte in uscita**.
- **Entità coinvolte:** persona/utente **support@tryhatme.com**, mittente **eileen@trendymillineryco.me** e **dominio sospetto trendymillineryco.me**.
- **Remediation:** **bloccare gli IOC** sul **gateway email** e **rimuovere definitivamente** la **traccia del messaggio** dalla casella dell'utente.

Il Tuo Decalogo per il Futuro (Come ragionare da oggi in poi)

- **Non cliccare, osserva.** Leggi l>alert per intero.
- **Restringi il tempo.** Il **Time Picker** è il tuo migliore amico.
- **Trova il paziente zero.** Identifica il **bersaglio** dell'attacco.
- **Trova la prova dell'azione.** Cerca l'interazione logica **invertendo i campi** o usando l'IOC univoco.
- **Cerca l'esito.** Verifica se esiste un **blocco**, un'assenza di eventi o una **comunicazione riuscita**.
- **Scrivi tutto.** Estrai gli **IOC** durante l'indagine, non alla fine.